

ZERO TRUST SECURITY FOR BANKING INFRASTRUCTURE

Security Architecture Policy Paper & Implementation Framework

Document Type:	Policy Paper / Security Architecture Framework
Classification:	Confidential – Regulatory Submission
Prepared by:	Cybersecurity Governance & Architecture Unit
Target Audience:	Reserve Bank of India (RBI) – CSITE / DPSS
Date:	June 2025
Version:	1.0 – Final

ABSTRACT

The traditional perimeter-based 'castle-and-moat' security model is fundamentally inadequate for modern banking infrastructure, which spans on-premise data centres, multi-cloud environments, remote workforces, third-party APIs, and interconnected payment networks. This policy paper advocates for the adoption of the Zero Trust Architecture (ZTA) model – predicated on the principle of 'Never Trust, Always Verify' – as the strategic security framework for Indian banking institutions regulated by the Reserve Bank of India (RBI). Drawing upon NIST SP 800-207, CISA's Zero Trust Maturity Model, and international banking sector implementations, this paper presents a phased ZTA roadmap, identifies implementation challenges specific to the Indian banking context, and provides policy recommendations for RBI regulatory alignment.

1. INTRODUCTION & POLICY RATIONALE

Banking infrastructure in India has undergone a paradigm shift. The Jan Dhan-Aadhaar-Mobile (JAM) trinity, the UPI revolution processing over 13.89 billion transactions in March 2024 alone, and the proliferation of open banking APIs have created a financial ecosystem of unprecedented scale and complexity. This digital expansion has dissolved the traditional network perimeter – the foundational assumption upon which legacy security architectures were built.

Conventional network perimeter security relies on the implicit trust of users and devices located within a defined network boundary. This assumption is systematically invalidated by modern threat actors who: (i) exploit stolen credentials to operate as legitimate insiders; (ii) move laterally through flat network architectures undetected; and (iii) abuse trust relationships between interconnected financial systems to escalate access and exfiltrate data.

Zero Trust Architecture (ZTA), codified by NIST in Special Publication 800-207 (2020), establishes that no user, device, or network segment should be inherently trusted – regardless of whether the request

originates from inside or outside the organisational perimeter. Access is granted on a per-session basis following continuous verification of identity, device health, and contextual risk signals. For banking institutions, this paradigm shift is not merely a security upgrade – it is a strategic imperative for operational resilience.

2. ZERO TRUST ARCHITECTURE – CORE PRINCIPLES

ZTA is defined by seven foundational tenets as articulated in NIST SP 800-207:

- All data sources and computing services are considered resources, regardless of location.
- All communication is secured irrespective of network location – encrypted, authenticated end-to-end.
- Access to individual enterprise resources is granted on a per-session basis with minimum necessary privilege.
- Access to resources is determined by dynamic policy – incorporating identity, behavioural analytics, and device posture.
- The enterprise monitors and measures the integrity and security posture of all owned and associated assets.
- All resource authentication and authorisation are dynamic and strictly enforced before access is allowed.
- The enterprise collects information about the current state of assets, network infrastructure, and communications to improve security posture.

The Five Pillars of Zero Trust for Banking

IDENTITY	DEVICES	NETWORKS	APPS	DATA
Verify every user every time	Validate endpoint health & posture	Micro-segment & monitor all traffic	Least-privilege access per session	Classify, encrypt & control data

Figure 1: Five Core Pillars of Zero Trust Architecture – Banking Context

3. ZERO TRUST IN THE BANKING CONTEXT

3.1 Identity & Access Management as the Control Plane

In a Zero Trust banking architecture, identity becomes the new security perimeter. Every access request – whether from a bank employee accessing core banking systems, a third-party auditor reviewing financial records, or an API call from a fintech partner – must be authenticated, authorised, and continuously validated.

Implementation mandates Multi-Factor Authentication (MFA) for all privileged users (100% coverage), deployment of a modern Identity Provider (IdP) with SAML 2.0 / OpenID Connect support, and integration of risk-based conditional access policies that evaluate device compliance, location anomaly, and user behaviour patterns in real time before granting system access.

3.2 Micro-Segmentation of Banking Networks

Traditional flat network architectures enable adversaries to move laterally with minimal obstruction once initial access is achieved. Zero Trust mandates network micro-segmentation – dividing the banking network into granular security zones that enforce least-privilege communication policies.

- Core Banking System (CBS) Zone: isolated from all external and internet-facing systems; access restricted to authorised application servers only.
- Payment Processing Zone: RTGS/NEFT/UPI transaction servers isolated with dedicated firewall policies and encrypted inter-zone communication.
- Customer-Facing Zone: DMZ architecture for internet banking portals with WAF, bot protection, and DDoS mitigation.
- Management Zone: dedicated out-of-band management network for IT administration with jump server enforcement.
- Third-Party / API Zone: isolated API gateway with per-partner rate limiting, OAuth 2.0 authentication, and API security scanning.

3.3 Device Trust and Endpoint Validation

In a Zero Trust model, every device seeking network access must demonstrate a validated security posture prior to connection establishment. For banking institutions, this entails deployment of a Device Trust framework comprising: Mobile Device Management (MDM) for all employee and contractor devices; continuous compliance checks for operating system patch levels, encryption status, and AV signature currency; certificate-based device authentication; and automated quarantine of non-compliant or anomalous devices.

3.4 Data-Centric Security Controls

The DPDP Act 2023 and RBI's data localisation requirements necessitate granular data classification and protection controls. Zero Trust data security for banking encompasses:

- Data classification into tiers: Public, Internal, Confidential, Restricted (e.g., Aadhaar-linked records, SWIFT credentials, cardholder data).
- Encryption at rest (AES-256) and in transit (TLS 1.3 minimum) for all classified data.
- Data Loss Prevention (DLP) policies enforced at endpoints, email gateways, and cloud egress points.
- Database Activity Monitoring (DAM) for core banking and customer data repositories.
- Rights Management enforcement – preventing unauthorised copying, printing, or forwarding of classified financial documents.

3.5 Zero Trust Maturity Levels – Banking Sector

CISA's Zero Trust Maturity Model defines four maturity stages. Banks should target Optimal maturity within 36 months:

Traditional	Implicit trust; perimeter firewall; basic MFA	~45% of PSBs (2024)
Initial	Identity-centric; some segmentation; limited telemetry	~30% of Private Banks
Advanced	Automated policy; SIEM/SOAR integrated; API control	~20% (Large Pvt Banks)
Optimal	AI-driven; fully automated; continuous validation	<5% (HDFC, ICICI, SBI-YONO)

Table 3: CISA Zero Trust Maturity Model – Indian Banking Sector Assessment (Estimated, 2024)

4. IMPLEMENTATION ROADMAP

A phased implementation approach is recommended to manage operational risk and align with RBI supervisory timelines:

Phase	Timeline	Key Deliverables
Phase 1 Foundation	0–6 Months	MFA (all privileged users), IAM audit, asset inventory, network segmentation design, ZTA
Phase 2 Identity & Device	6–18 Months	IdP deployment, MDM rollout, device compliance enforcement, PAM implementation, SIE
Phase 3 Network & Data	18–30 Months	Micro-segmentation deployment, API gateway ZTA controls, DLP rollout, data classification
Phase 4 Automation	30–42 Months	SOAR integration, AI/ML behavioural analytics, full UEBA deployment, ZTA maturity asse

Table 4: Phased Zero Trust Implementation Roadmap for Banking Institutions

5. IMPLEMENTATION CHALLENGES

While Zero Trust offers compelling security benefits, implementation within the Indian banking sector presents specific challenges that must be proactively addressed:

- Legacy Core Banking Systems – Mainframe CBS platforms lack native support for modern identity protocols (OAuth, SAML) and cannot host agent-based endpoint monitoring, requiring bespoke integration or proxy architectures.
- Operational Disruption Risk – Transitioning from implicit to explicit trust-based access can disrupt banking operations if not carefully managed through phased deployment and extensive user acceptance testing.
- Workforce Capability Gap – ZTA requires advanced competencies in IAM, cloud security, and network architecture. Indian banking sector faces a deficit of approximately 30,000 qualified cybersecurity professionals (DSCI 2024).
- Third-Party Integration Complexity – The dense ecosystem of fintech partners, payment aggregators, and outsourced IT vendors creates integration challenges for ZTA policy enforcement at API and network boundaries.
- Cost of Implementation – Full ZTA deployment for a mid-sized Indian bank is estimated at INR 15–40 crore, requiring CFO-level justification and RBI guidance on capital treatment of cybersecurity investments.

INTERNATIONAL BENCHMARKS – ZTA IN BANKING
• U.S. Federal Reserve: Mandated ZTA adoption for all Federal Reserve System member banks by 2024 (OMB M-22-09).
• Monetary Authority of Singapore (MAS): TRM Guidelines require banks to implement identity-centric access controls aligned with ZTA principles.
• European Central Bank (ECB): TIBER-EU framework incorporates ZTA principles in threat-led penetration testing for systemic banks.

- JPMorgan Chase: Completed enterprise-wide ZTA deployment across 250,000+ employees and 6,000+ applications (2023).
- DBS Bank Singapore: Recognised by Gartner as a Zero Trust 'Leader' – implemented full microsegmentation of core banking infrastructure.

6. REGULATORY ALIGNMENT & POLICY RECOMMENDATIONS

The following policy recommendations are directed to the Reserve Bank of India to facilitate systematic ZTA adoption across the Indian banking sector:

Recommendation 1: RBI ZTA Directive	Issue a formal Master Direction mandating Zero Trust Architecture adoption for Scheduled Commercial Banks (SCBs) with more than INR 10,000 crore in assets, with a phased compliance timeline of 36 months.
Recommendation 2: ZTA Maturity Assessment	Require annual ZTA maturity self-assessment using the CISA ZTA Maturity Model framework, submitted to RBI's CSITE division as part of the Annual Report on Cybersecurity Governance.
Recommendation 3: Regulatory Sandbox	Establish a ZTA implementation sandbox allowing banks to pilot micro-segmentation and identity federation technologies in controlled environments without full production risk.
Recommendation 4: Capacity Building	Direct Indian Banks' Association (IBA) to develop a ZTA Certification Programme for cybersecurity professionals, targeting 5,000 trained ZTA practitioners within 3 years.
Recommendation 5: Shared Intelligence	Mandate contribution to and consumption of the RBI Threat Intelligence Sharing Platform (TISP) as part of ZTA implementation, enabling network-level threat indicators to feed dynamic access policy engines.
Recommendation 6: Third-Party Standards	Extend ZTA compliance requirements to critical third-party service providers (cloud providers, IT outsourcing vendors, payment aggregators) through contractual mandates and RBI third-party audit rights.

7. CONCLUSION

Zero Trust Architecture represents the most robust and strategically sound security framework available for protecting the complex, interconnected, and data-intensive infrastructure of modern banking. In the context of India's rapidly expanding digital financial ecosystem, the migration from perimeter-based to identity-centric, least-privilege security is not an aspirational long-term goal – it is an urgent operational

necessity.

The principles of Zero Trust – continuous verification, least-privilege access, micro-segmentation, and assume-breach posture – directly address the attack vectors most frequently exploited in financial sector breaches: credential theft, lateral movement, and insider privilege abuse. By adopting ZTA, Indian banks will not only strengthen their own resilience but contribute to the systemic stability of a financial infrastructure that is increasingly foundational to India's national economic security.

The RBI has a critical role to play in catalysing this transition – through clear regulatory mandates, implementation guidance, capacity-building initiatives, and supervisory recognition of ZTA maturity as a positive indicator in cyber risk assessments. The convergence of regulatory will, institutional capability, and technological maturity creates a unique window of opportunity to fundamentally transform cybersecurity governance across India's banking sector.

REFERENCES

- [1] NIST. (2020). Zero Trust Architecture – Special Publication 800-207. National Institute of Standards and Technology.
- [2] CISA. (2023). Zero Trust Maturity Model Version 2.0. Cybersecurity and Infrastructure Security Agency.
- [3] OMB. (2022). Moving the U.S. Government Toward Zero Trust Cybersecurity Principles. M-22-09. Office of Management and Budget.
- [4] Reserve Bank of India. (2016). Cyber Security Framework in Banks. RBI/2015-16/418.
- [5] Reserve Bank of India. (2023). Draft Cyber Resilience and Digital Payment Security Controls for Payment System Operators.
- [6] DSCI. (2024). India Cybersecurity Report 2024. Data Security Council of India.
- [7] MAS. (2021). Technology Risk Management Guidelines. Monetary Authority of Singapore.
- [8] Gartner. (2024). Magic Quadrant for Zero Trust Network Access (ZTNA). Gartner Research.
- [9] Ministry of Electronics & IT. (2023). Digital Personal Data Protection Act, 2023. Government of India.
- [10] NPCI. (2024). UPI Transaction Statistics – March 2024. National Payments Corporation of India.
- [11] Forrester Research. (2023). Zero Trust Wave Report – Identity & Access Management. Forrester.
- [12] DSCI & Nasscom. (2023). State of Cybersecurity in the Indian Banking, Financial Services and Insurance (BFSI) Sector.
- [13] John Kindervag. (2010). No More Chewy Centers: Introducing The Zero Trust Model Of Information Security. Forrester Research.

This document is prepared for submission to the Reserve Bank of India as a cybersecurity architecture policy paper. All frameworks, maturity assessments, and policy recommendations are based on publicly available standards, regulatory guidance, and industry research.